

STUDENT	HASSANI Mohammad Salem	INSTRUCTOR	Asen Grozdanov
DATE	January 9, 2026	COURSE	Managing Vulnerabilities

PART 1 — RISK SCORING FUNDAMENTALS

1.1 · CVSS Limitations Analysis

CVSS Base Scores are designed for generic environments and therefore ignore organisational context. For **CVE-2025-64446** (CVSS 9.8), the Base Score overemphasises theoretical impact without accounting for whether the affected product is deployed, whether the network is internet-facing, or whether active exploit code exists in the wild. A lower-scored vulnerability with a confirmed CISA KEV entry may represent a greater real-world risk than a theoretical CVSS 9.8.

1.2 · Business Asset Mapping

Assets were catalogued and assigned criticality ratings based on the potential business disruption caused by a successful compromise:

Asset	Examples	Criticality	Disruption Impact
Student Information System	Records Database	Critical	Regulatory fines + enrollment loss
Learning Management System	Online course platform	High	Classes disrupted
Admin Workstations	Staff PCs	Medium	Productivity loss
Public Web Server	Marketing site	Medium	Reputation damage
Network Infrastructure	Firewalls, switches	Critical	Full network outage

PART 2 — FRAMEWORK DEVELOPMENT

2.1 · Multi-Factor Risk Model

A weighted scoring model was developed to produce a single composite Risk Score that combines technical severity with real-world threat context:

$$\text{Risk} = (\text{CVSS} \times 0.25) + (\text{Exploit} \times 0.30) + (\text{Asset} \times 0.25) + (\text{Exposure} \times 0.20)$$

Component	Weight	Data Source	Scale	Example Value
Technical Severity	25%	NVD CVSS	0 – 10	9.8
Exploitation Evidence	30%	CISA KEV	0 – 10	10 (Active)
Asset Criticality	25%	Asset Inventory	0 – 10	10 (Critical)
Network Exposure	20%	Attack Vector	0 – 10	10 (Network)

Exploitation Evidence carries the highest weight (30%) — a confirmed in-the-wild exploit represents a more urgent threat than theoretical severity alone.

2.2 · Applied Results

The model was applied to five active vulnerabilities. Results and recommended remediation timelines are shown below:

CVE	Product	CVSS	Exploit	Asset	Exposure	Risk Score	Action
CVE-2025-64446	Fortinet FortiWeb	9.8	10	10	10	9.95	■ 24 hours
CVE-2025-22225	VMware ESXi	8.5	10	10	9	9.45	7 days
CVE-2026-1281	Ivanti	9.8	8	8	10	9.14	7 days
CVE-2019-19006	Sangoma FreePBX	7.5	10	7	8	8.05	7 days
CVE-2026-20805	Microsoft Windows	5.5	10	5	4	6.75	30 days

Validation: CVE-2026-20805 carries only a CVSS 5.5, yet scores 6.75 due to confirmed active exploitation (CISA KEV). The framework correctly elevates it above its raw base score, demonstrating that exploit evidence outweighs theoretical severity.

PART 3 — STAKEHOLDER COMMUNICATION

3.1 · Executive Summary

TO:	College Principal
FROM:	Security Analyst — Threat Intelligence
DATE:	February 4, 2026
SUBJECT:	Critical Threat Alert — Fortinet FortiWeb & VMware ESXi

Overview: This month's threat intelligence cycle has surfaced two critical risks requiring immediate executive attention: the active exploitation of perimeter firewalls via a public proof-of-concept, and renewed ransomware campaigns targeting core virtualisation infrastructure.

Critical Findings:

- **Fortinet FortiWeb (CVE-2025-64446):** CVSS 9.8 — unauthenticated attackers can fully bypass the WAF. Public exploit code is available, increasing script-kiddie risk. Affects student data confidentiality and network perimeter integrity.
- **VMware ESXi (CVE-2025-22225):** CISA confirmed ransomware groups are actively exploiting this flaw. Unpatched ESXi hosts face imminent risk of workload encryption and extended downtime.

Recommended Actions:

- ✓ Patch all internet-facing Fortinet FortiWeb appliances to version 8.0.2 **within 24 hours** (est. cost: \$2,000).
- ✓ Conduct an immediate audit of all ESXi hosts — confirm March 2025 security updates are applied **within 7 days**.
- ✓ Validate network segmentation around virtualisation clusters to limit lateral movement.

3.2 · Remediation Roadmap

Vulnerability	Owner	Start	Complete By	Dependencies	Verification
---------------	-------	-------	-------------	--------------	--------------

CVE-2025-64446 (Fortinet FortiWeb)	Network Admin	Feb 8	Feb 9	Vendor patch available	Vulnerability scanner
CVE-2025-22225 (VMware ESXi)	Systems Admin	Feb 8	Feb 14	Patch Tuesday cycle	System logs + audit

3.3 · Reflection

Key Challenge: Reconciling raw CVSS scores with real-world exploitation evidence. The custom risk model resolves this by assigning higher weight to exploitation evidence (30%) than to technical severity (25%).

Key Insight: CVE-2019-19006 — a 2019 Sangoma FreePBX flaw — was added to the CISA KEV catalog in 2026. This confirms that legacy systems remain primary attack targets even years after initial disclosure. Patch management must account for historical vulnerabilities, not only new CVEs.

Professional Application: The lab workflow mirrors a real SOC analyst cycle: ingest threat data → apply a risk model → translate findings into business-relevant recommendations for executive leadership.

Tools Used:

- **NVD (nvd.nist.gov):** CVE details, CVSS scores, CWE classification
- **CISA KEV Catalog:** Confirmed in-the-wild exploitation data
- **FIRST EPSS:** Exploit Prediction Scoring System
- **Feedly:** OSINT aggregation — BleepingComputer, The Hacker News